

SIMATS ENGINEERING

ASSESSMENT TOOL 2(MEDIUM)

COURSE NAME: Ethical Hacking

COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO3: Analyze network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities. (BT4)

Assessment Tool Weightage: 30%

Duration: 90 min

Total Marks: 50

Port Scanning Challenge

1. Using Nmap, perform a security assessment on the server 192.168.1.20. Identify all open ports and running services. Analyze the purpose of each discovered service and recommend security measures to reduce the attack surface of the system.

A. Performing a security assessment using Nmap helps identify the network services exposed by the server and determine whether those services introduce unnecessary security risks. The goal is to identify all open ports, understand the purpose of the associated services, analyze their security implications, and recommend measures to reduce the attack surface of the system.

Here is a structured approach to assessing the server:

1. Open Port and Service Identification

The first step is to examine the Nmap results and identify all ports reported as open along with the services running on them.

- **Port Identification:** Each open port represents a service that is accepting network connections. The port number helps identify the type of service, such as SSH, HTTP, FTP, SMB, or a database service.
- **Service Identification:** Determine the service associated with each open port. For example, port 22 commonly provides SSH, port 80 provides HTTP, and port 443 provides HTTPS.
- **Version Identification:** Identify the software and version running behind each service. This is important because outdated versions may contain known security vulnerabilities.
- **Operating System Information:** The assessment can also provide information about the underlying operating system, which helps in understanding the security environment of the server.

2. Purpose and Security Analysis of Discovered Services

Each discovered service should be analyzed according to its purpose and security risk.

- **SSH:** SSH is normally used for secure remote administration. Although it provides encrypted communication, weak passwords, unrestricted access, or outdated configurations can allow unauthorized login attempts.
- **HTTP/HTTPS:** These services are used to host websites and web applications. Vulnerabilities in the web server, outdated software, exposed directories, or insecure applications may provide attackers with possible entry points.

- **FTP:** FTP is used for file transfer. Standard FTP can transmit authentication information without encryption and may also be affected by anonymous-access or configuration problems.
- **SMB:** SMB is commonly used for file and printer sharing, particularly in Windows environments. Improper configuration or outdated SMB versions can expose sensitive resources or increase the risk of unauthorized access.
- **Database Services:** Database services are used to store and manage application data. If they are unnecessarily exposed to the network, attackers may attempt unauthorized access, password attacks, or exploitation of database vulnerabilities.

3. Risk Assessment

After identifying the services, their security risks should be evaluated based on their necessity, exposure, configuration, and software version.

- **Unnecessary Services:** A service that is not required for the server's operation creates an unnecessary entry point and should be disabled.
- **Outdated Services:** Old versions of server software may contain publicly known vulnerabilities and should be updated.
- **Internet or Network Exposure:** Services accessible from a large number of systems have a greater attack surface than services restricted to trusted users.
- **Weak Authentication:** Services that use weak passwords, default credentials, or unrestricted login attempts are more vulnerable to unauthorized access.
- **Sensitive Services:** Administrative and database services require stronger protection because compromise could provide access to important system resources or data.

4. Security Measures to Reduce the Attack Surface

Based on the Nmap findings, the following security measures should be implemented:

1. **Disable Unnecessary Services:** Services that are not required should be stopped and their associated ports should be closed.
2. **Firewall Configuration:** Configure the firewall to permit only the ports required for legitimate business operations.
3. **Restrict Administrative Services:** Remote administration services such as SSH should be accessible only to authorized users and trusted systems.
4. **Update Software:** Keep the operating system, web servers, remote-access services, and other applications updated with security patches.
5. **Use Strong Authentication:** Use strong passwords, key-based authentication where appropriate, and disable unnecessary default accounts.
6. **Secure Web Services:** Protect web applications using HTTPS, secure configurations, proper access controls, and regular security updates.
7. **Protect Database Services:** Database ports should not be unnecessarily exposed to untrusted networks. Access should be restricted to authorized application servers and administrators.
8. **Replace Insecure Protocols:** Insecure services such as traditional FTP should be replaced with secure alternatives where possible.

9. Monitor Network Activity: Regularly monitor authentication logs and network connections for suspicious activity.

5. Actionable Security Priority

The identified findings can be categorized according to their security importance:

- Critical / P1: An exposed service has a serious known vulnerability, provides access to sensitive data, or allows unauthorized remote access.

Action: Fix immediately and restrict or disable the service.

- High / P2: An exposed service is outdated, poorly configured, or accessible to unauthorized networks but does not currently present a critical vulnerability.

Action: Remediate during the next security patch cycle.

- Medium / P3: The service is required but has configuration weaknesses or unnecessary exposure.

Action: Apply security hardening and restrict access.

- Low / Informational: The service is required and properly secured, but information such as service versions or unnecessary network exposure is revealed.

Action: Apply security best practices and continue monitoring.

Example

If the Nmap assessment identifies services such as SSH, HTTP, SMB, and a database service, I would first determine whether each service is actually required.

If SSH is required for administration, access should be restricted to authorized administrators. If HTTP/HTTPS is required for a website, the web server should be patched and securely configured. If SMB is not required, it should be disabled or blocked. Similarly, a database service should not be directly accessible to untrusted networks and should be restricted to the systems that require database access.

Therefore, an unnecessary or vulnerable service would receive a higher priority than a required service that is properly configured and protected.

Conclusion

The Nmap assessment of 192.168.1.20 helps identify the server's open ports, running services, and potential security weaknesses. Each discovered service must be evaluated according to its purpose, necessity, exposure, and configuration. Unnecessary services should be disabled, required services should be updated and hardened, and firewall rules should restrict access to trusted systems. These measures reduce the attack surface and improve the overall security of the server.

```
kali@kali: ~  
Session Actions Edit View Help  
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows  
Host script results:  
_ smb2-security-mode:  
  3:1:1:  
_ Message signing enabled and required  
_ smb2-time:  
  date: 2026-08-08T04:08:09  
_ start_date: N/A  
TRACEROUTE (using port 80/tcp)  
HOP RTT ADDRESS  
1 0.76 ms 192.168.56.1  
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 26.09 seconds  
(kali@kali)-[~]  
$ sudo nmap -O 192.168.56.1  
sudo: nmap-0: command not found  
(kali@kali)-[~]  
$ sudo nmap -O 192.168.56.1  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-08 00:09 EDT  
Nmap scan report for 192.168.56.1  
Host is up (0.0019s latency).  
Not shown: 994 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
135/tcp   open  msrpc  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
902/tcp   open  iss-realsecure  
912/tcp   open  apex-mesh  
3306/tcp   open  mysql  
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port  
Device type: bridge|VoIP adapter|general purpose  
Running (JUST GUESSING): Oracle Virtualbox (98%), Slirp (98%), AT&T embedded (95%), QEMU (94%)  
OS CPE: cpe:/o:oracle:virtualbox cpe:/a:danny_gasparovski:slirp cpe:/a:qemu:qemu  
Aggressive OS guesses: Oracle Virtualbox Slirp NAT bridge (98%), AT&T BGW210 voice gateway (95%), QEMU user mode network gateway (94%)  
No exact OS matches for host (test conditions non-ideal).  
OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 9.13 seconds
```

2. Using Nikto, assess the web server hosted on 192.168.1.30. Identify potential webserver misconfigurations, outdated components, or exposed files and directories. Discuss the security risks associated with your findings and suggest appropriate mitigation strategies.

A. Performing a web-server security assessment using Nikto helps identify common web-server misconfigurations, outdated software components, insecure files, directories, and other weaknesses. The goal is to understand the security risks associated with the discovered findings and recommend appropriate measures to secure the web server.

Here is a structured approach to assessing the web server:

1. Web Server and Component Identification

The first step is to examine the Nikto assessment results and identify the web server software, its version, and the components running on the server.

- **Web Server Identification:** Determine the type of web server being used, such as Apache, Nginx, or Microsoft IIS.
- **Version Detection:** Identify the version of the web server and other visible components. Older versions may contain known security vulnerabilities.
- **Server Configuration:** Examine the server configuration for unnecessary features, insecure settings, directory listing, and information disclosure.
- **HTTP Security Headers:** Check whether important security headers are properly configured to protect users from common web attacks.

2. Identification of Misconfigurations and Exposed Resources

The next step is to analyze the findings reported by Nikto and identify potentially dangerous files, directories, and configurations.

- **Directory Listing:** If directory browsing is enabled, users may be able to view files and folders that should not be publicly accessible.

- **Exposed Files:** Backup files, configuration files, temporary files, log files, and other sensitive files may reveal important information about the web application.
- **Default Files:** Default pages and sample files provided by the web server may reveal information about the server software and its configuration.
- **Administrative Directories:** Exposed administration or management directories may provide attackers with additional opportunities to discover or target sensitive functionality.
- **HTTP Methods:** Unnecessary or insecure HTTP methods may allow unwanted operations if they are not properly restricted.

3. Outdated Components and Vulnerabilities

Outdated components are an important security concern because known vulnerabilities may already be publicly documented.

- **Outdated Web Server:** An old version of Apache, Nginx, IIS, or another web server may contain known vulnerabilities.
- **Outdated Applications:** Web applications, frameworks, plugins, or modules should be checked for known security issues.
- **Known Vulnerabilities:** Identified software versions should be compared with trusted vulnerability databases to determine whether security patches are available.
- **Information Disclosure:** Server banners and version information can help attackers identify the software being used and search for corresponding vulnerabilities.

4. Security Risks Associated with the Findings

The discovered weaknesses can create several security risks:

- **Information Disclosure:** Exposed files, directory listings, and server-version information can reveal useful details about the web server and application.
- **Unauthorized Access:** Poorly protected administrative directories or files may allow unauthorized users to access sensitive functionality.
- **Data Exposure:** Backup, configuration, or log files may contain usernames, credentials, database details, or other sensitive information.
- **Exploitation of Known Vulnerabilities:** Outdated web-server components may contain publicly known vulnerabilities that attackers could attempt to exploit.
- **Web Application Attacks:** Weak server configurations can increase the possibility of attacks against the hosted web application.
- **Increased Attack Surface:** Unnecessary files, directories, modules, and services provide additional resources that attackers can investigate or target.

5. Mitigation Strategies

Based on the Nikto findings, the following security measures should be implemented:

1. **Update the Web Server:** Install the latest security updates and patches for the web server and its components.

2. Remove Unnecessary Files: Delete default pages, sample applications, backup files, temporary files, and other unnecessary resources.
3. Disable Directory Listing: Prevent users from browsing directories that do not contain a public index page.
4. Protect Sensitive Files: Ensure configuration files, logs, backups, and other sensitive resources cannot be accessed through the web server.
5. Restrict Administrative Areas: Administrative directories should require proper authentication and should be accessible only to authorized users.
6. Hide Server Information: Reduce unnecessary disclosure of web-server and software version information in HTTP responses.
7. Configure Security Headers: Implement appropriate HTTP security headers to provide additional protection for web users and applications.
8. Disable Unnecessary Features: Remove or disable unused modules, HTTP methods, and web-server functionality.
9. Use HTTPS: Protect web communication using properly configured HTTPS and secure TLS settings.
10. Regular Security Assessment: Perform periodic vulnerability assessments to identify newly introduced vulnerabilities and configuration weaknesses.

6. Actionable Security Priority

The findings can be prioritized according to their potential impact:

- Critical / P1: Exposed sensitive files, serious known vulnerabilities, or weaknesses that could lead to unauthorized access.

Action: Fix immediately and remove public exposure.

- High / P2: Outdated web-server components, exposed administrative resources, or significant configuration weaknesses.

Action: Apply security patches and harden the configuration as soon as possible.

- Medium / P3: Directory listing, unnecessary HTTP methods, or other configuration weaknesses that provide additional information or attack opportunities.

Action: Correct during the next security-hardening cycle.

- Low / Informational: Server banners, minor information disclosure, or other best-practice issues.

Action: Reduce information disclosure and include the issue in regular security maintenance.

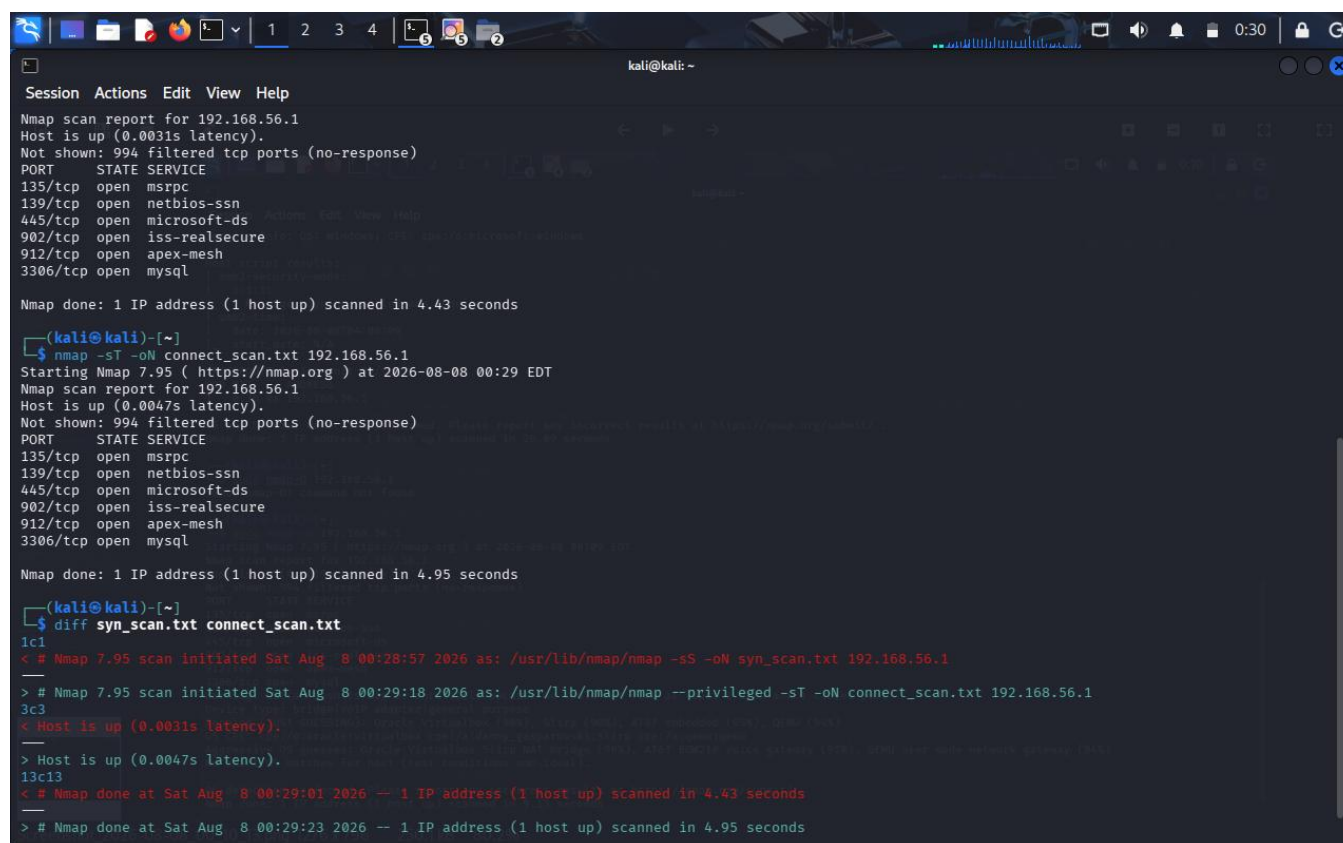
Example

If the Nikto assessment identifies an outdated web-server version, directory listing, default files, and an exposed backup file, the backup file would receive a high priority because it may contain sensitive application or configuration information.

The outdated web server should then be updated to a supported version. Directory listing should be disabled, default files should be removed, and the backup file should be deleted or moved to a location that is not publicly accessible.

Conclusion

The Nikto assessment of web server 192.168.1.30 helps identify misconfigurations, outdated components, exposed files and directories, and information-disclosure issues. Each finding should be evaluated according to its severity and potential impact. Updating software, removing unnecessary files, restricting sensitive resources, disabling directory listing, and applying secure web-server configurations can significantly reduce the attack surface and improve the security of the web server. The assessment question specifically requires identifying these web-server weaknesses, discussing their risks, and recommending appropriate mitigation strategies.



```
kali@kali: ~  
Session Actions Edit View Help  
Nmap scan report for 192.168.56.1  
Host is up (0.0031s latency).  
Not shown: 994 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
135/tcp    open  msrpc  
139/tcp    open  netbios-ssn  
445/tcp    open  microsoft-ds  
902/tcp    open  iss-realservice  
912/tcp    open  apex-mesh  
3306/tcp   open  mysql  
  
Nmap done: 1 IP address (1 host up) scanned in 4.43 seconds  
  
(kali@kali)-[~]  
$ nmap -sT -oN connect_scan.txt 192.168.56.1  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-08 00:29 EDT  
Nmap scan report for 192.168.56.1  
Host is up (0.0047s latency).  
Not shown: 994 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
135/tcp    open  msrpc  
139/tcp    open  netbios-ssn  
445/tcp    open  microsoft-ds  
902/tcp    open  iss-realservice  
912/tcp    open  apex-mesh  
3306/tcp   open  mysql  
  
Nmap done: 1 IP address (1 host up) scanned in 4.95 seconds  
  
(kali@kali)-[~]  
$ diff syn_scan.txt connect_scan.txt  
1c1  
< # Nmap 7.95 scan initiated Sat Aug  8 00:28:57 2026 as: /usr/lib/nmap/nmap -sS -oN syn_scan.txt 192.168.56.1  
---  
> # Nmap 7.95 scan initiated Sat Aug  8 00:29:18 2026 as: /usr/lib/nmap/nmap --privileged -sT -oN connect_scan.txt 192.168.56.1  
3c3  
< Host is up (0.0031s latency).  
---  
> Host is up (0.0047s latency).  
13c13  
< # Nmap done at Sat Aug  8 00:29:01 2026 -- 1 IP address (1 host up) scanned in 4.43 seconds  
---  
> # Nmap done at Sat Aug  8 00:29:23 2026 -- 1 IP address (1 host up) scanned in 4.95 seconds
```

3. Using Netcat (nc), investigate the host 192.168.1.40 by connecting to open ports and collecting available service banners. Analyze the information obtained and explain how attackers could use banner information during the reconnaissance phase of an attack.

A. Performing a security assessment using Netcat (nc) helps investigate open ports and collect available service banners from the host. The goal is to identify the services running on the target, analyze the information revealed by their banners, and understand how attackers could use this information during the reconnaissance phase of an attack.

Here is a structured approach to assessing the host:

1. Open Port and Service Identification

The first step is to identify the open ports on 192.168.1.40 and connect to the services that are accepting connections.

- **Port Identification:** An open port indicates that a service is listening and accepting network connections. The port number can provide an initial indication of the type of service running.
- **Service Identification:** By connecting to an open port, the response from the server can help determine whether the service is HTTP, SSH, FTP, SMTP, or another network service.

- **Banner Collection:** A service banner may provide information such as the service name, software product, version number, operating system information, or other configuration details.
- **Service Verification:** The collected response can be compared with the expected service for that port to determine whether the identified service is actually running.

2. Analysis of Service Banner Information

The information obtained from the banners should be carefully analyzed because it can reveal useful details about the host.

- **Software Name:** The banner may reveal the exact software providing the service, such as Apache, OpenSSH, or another server application.
- **Version Information:** A version number can indicate whether the software is current or outdated. Specific software versions may have known security vulnerabilities.
- **Operating System Information:** Some services may reveal operating-system details, helping an attacker understand the environment of the target.
- **Service Configuration:** Certain banners may reveal additional configuration information, supported protocols, or authentication mechanisms.
- **Unnecessary Information Disclosure:** If a server provides more information than necessary, it gives an attacker additional knowledge that can be used during reconnaissance.

3. Security Risks of Banner Information

Service banners can create several security risks:

- **Information Disclosure:** Detailed banners reveal information about the technologies and software used by the host.
- **Version-Based Targeting:** If an outdated software version is identified, an attacker can search for publicly known vulnerabilities affecting that specific version.
- **Targeted Attacks:** Knowing the exact service and version allows attackers to select attacks that are appropriate for the identified technology.
- **Operating System Fingerprinting:** Information about the operating system can help attackers understand the target environment and select appropriate techniques.
- **Attack Surface Mapping:** By identifying several services, an attacker can create a clearer picture of the host's network-facing components.

4. How Attackers Use Banner Information During Reconnaissance

Banner information is particularly useful during the reconnaissance phase, where attackers gather information before attempting an attack.

1. **Identify Technologies:** Attackers determine which services and software are running on the target.
2. **Identify Versions:** They examine version numbers to determine whether the software is outdated.
3. **Research Vulnerabilities:** The identified software and versions can be compared with known vulnerability information.

4. **Select Attack Targets:** Attackers prioritize services that appear vulnerable or provide valuable access to the system.
5. **Plan Further Attacks:** The collected information helps attackers decide which techniques may be relevant to the target environment.

For example, if a banner reveals that a host is running an outdated version of a particular web server, an attacker can investigate vulnerabilities associated with that version. Similarly, identifying an SSH service can indicate that remote administration is available and may become a target for unauthorized login attempts.

5. Security Measures to Prevent Information Disclosure

The following measures can reduce the risks associated with service banners:

1. **Minimize Banner Information:** Configure services to reveal only the information that is necessary.
2. **Hide Software Versions:** Avoid unnecessarily displaying detailed software and version information in service responses.
3. **Keep Services Updated:** Regularly install security updates so that known vulnerabilities are addressed.
4. **Disable Unnecessary Services:** Services that are not required should be disabled and their ports closed.
5. **Use Firewall Rules:** Restrict access to services so that they are available only to authorized systems.
6. **Monitor Network Connections:** Monitor unusual connection attempts and repeated requests to multiple ports.
7. **Regular Security Assessments:** Periodically check exposed services to ensure that unnecessary information is not being disclosed.

6. Actionable Security Priority

The findings can be prioritized according to their potential security impact:

- **Critical / P1:** A banner reveals an outdated service with a serious known vulnerability and the service is accessible to untrusted users.
Action: Update or disable the service immediately and restrict network access.
- **High / P2:** An exposed service reveals detailed version information or has significant security weaknesses.
Action: Harden the service, update the software, and restrict access.
- **Medium / P3:** The service is required but provides unnecessary information through its banner.
Action: Reduce information disclosure and apply appropriate configuration changes.
- **Low / Informational:** Only basic service information is revealed without an identified vulnerability.
Action: Minimize unnecessary information and continue monitoring.

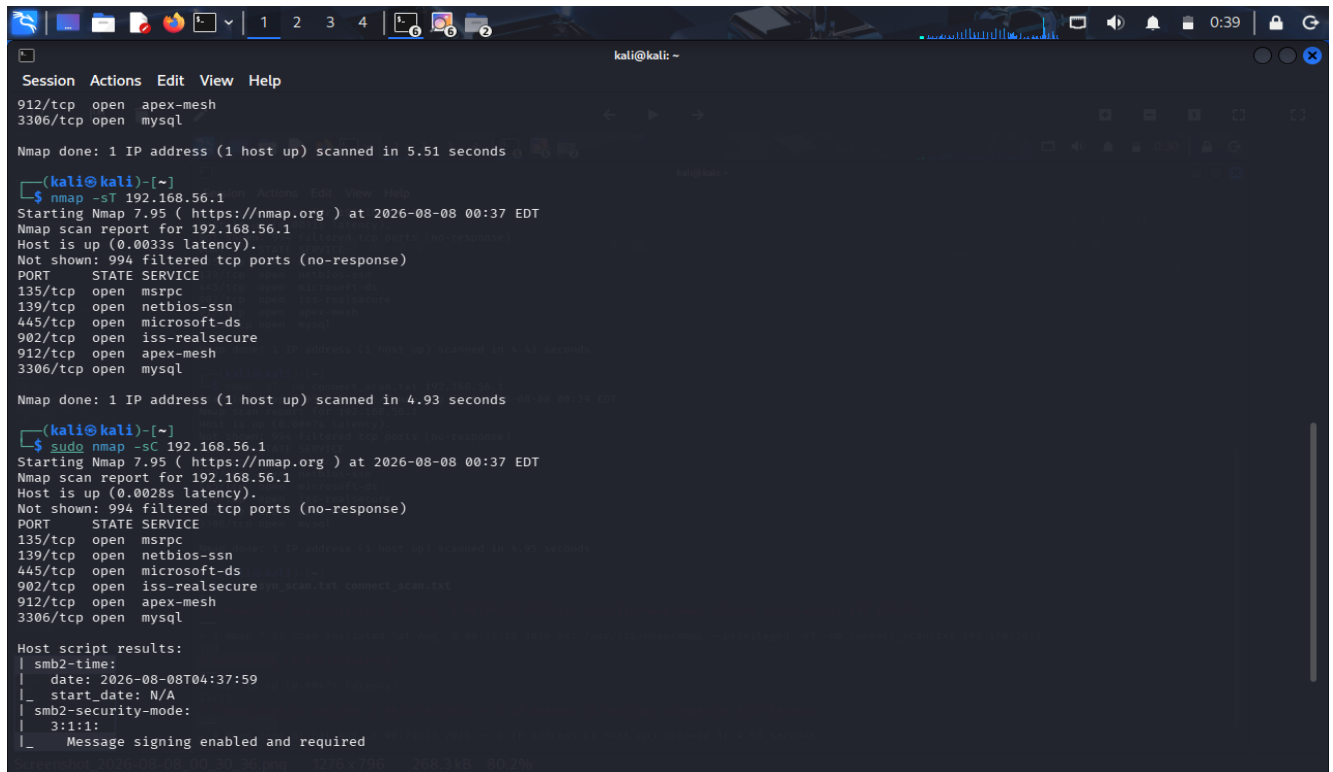
Example

If Netcat connects to an open port on 192.168.1.40 and the service banner reveals the software name and an outdated version, the information should be considered a security concern. An attacker could use the software and version information to search for known vulnerabilities and determine whether the service is a suitable target.

If the service is necessary, it should be updated to a supported version and configured to reveal minimal information. If the service is unnecessary, it should be disabled and the corresponding port should be closed.

Conclusion

Netcat can be used to investigate open services and collect service banner information from 192.168.1.40. Banner information can reveal software names, versions, operating-system details, and configuration information. Attackers can use these details during reconnaissance to identify technologies, research known vulnerabilities, and plan targeted attacks. Therefore, unnecessary services should be disabled, required services should be regularly updated, network access should be restricted, and excessive banner information should be minimized.



```
kali@kali: ~  
Session Actions Edit View Help  
912/tcp open apex-mesh  
3306/tcp open mysql  
Nmap done: 1 IP address (1 host up) scanned in 5.51 seconds  
  
(kali@kali)-[~]  
$ nmap -sT 192.168.56.1  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-08 00:37 EDT  
Nmap scan report for 192.168.56.1  
Host is up (0.0033s latency).  
Not shown: 994 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
135/tcp   open  mspc  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
902/tcp   open  iss-realservice  
912/tcp   open  apex-mesh  
3306/tcp   open  mysql  
Nmap done: 1 IP address (1 host up) scanned in 4.93 seconds  
  
(kali@kali)-[~]  
$ sudo nmap -sC 192.168.56.1  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-08 00:37 EDT  
Nmap scan report for 192.168.56.1  
Host is up (0.0028s latency).  
Not shown: 994 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
135/tcp   open  mspc  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
902/tcp   open  iss-realservice  
912/tcp   open  apex-mesh  
3306/tcp   open  mysql  
  
Host script results:  
_ smb2-time:  
| date: 2026-08-08T04:37:59  
|_ start_date: N/A  
_ smb2-security-mode:  
| 3:1:1:  
|_ Message signing enabled and required
```

4. Using Telnet, examine the server 192.168.1.50 to determine whether remote administration services are accessible. Identify any security concerns related to the discovered services and recommend more secure alternatives where appropriate.

A. Performing a security assessment using Telnet helps determine whether remote administration services are accessible on the server 192.168.1.50. The goal is to identify accessible remote services, analyze their security concerns, and recommend more secure alternatives for remote administration.

Here is a structured approach to assessing the server:

1. Identification of Remote Administration Services

The first step is to examine the accessible services on 192.168.1.50 and determine whether they provide remote administration capabilities.

- **Remote Service Identification:** Identify services that allow users or administrators to remotely connect to and manage the server.
- **Telnet Service:** If Telnet is accessible, it indicates that remote terminal access may be available. Telnet is considered insecure because it does not provide adequate protection for sensitive communication.
- **SSH Service:** SSH provides secure remote administration through encrypted communication and is generally preferred over Telnet for managing Unix/Linux systems.

- **Other Remote Administration Services:** Other services that provide remote management should also be examined to determine whether they are necessary and securely configured.

2. Analysis of Security Concerns

The discovered remote administration services should be evaluated for possible security weaknesses.

- **Unencrypted Communication:** Traditional Telnet transmits communication without strong encryption. Usernames, passwords, and commands may therefore be exposed to someone who can observe the network traffic.
- **Credential Exposure:** If authentication information is transmitted without encryption, attackers may potentially capture credentials and use them to gain unauthorized access.
- **Unauthorized Access:** An exposed remote administration service increases the possibility of brute-force attacks, password attacks, and unauthorized login attempts.
- **Weak Authentication:** Weak passwords or poorly configured authentication mechanisms can make remote administration services easier to compromise.
- **Excessive Network Exposure:** A remote administration service accessible from untrusted networks has a larger attack surface than one restricted to authorized administrators.

3. Risks Associated with Telnet

If Telnet is found to be accessible on the server, several security risks may exist:

- **Credential Sniffing:** Attackers monitoring network traffic may be able to obtain login credentials.
- **Session Exposure:** Commands and information exchanged during a Telnet session may be visible to an attacker.
- **Man-in-the-Middle Attacks:** Because Telnet does not provide adequate protection for the communication channel, an attacker positioned between the client and server may interfere with the session.
- **Unauthorized Administration:** Compromised credentials could allow an attacker to remotely access and control the server.
- **Increased Attack Surface:** Exposing an unnecessary remote administration service gives attackers another potential entry point.

4. Secure Alternatives

The following alternatives should be considered for safer remote administration:

1. **Replace Telnet with SSH:** SSH provides encrypted communication and is the preferred alternative for secure remote administration of Linux/Unix systems.
2. **Use Strong Authentication:** Strong passwords and, where appropriate, key-based authentication should be used to prevent unauthorized access.
3. **Disable Root Remote Login:** Direct remote login using highly privileged accounts should be restricted.
4. **Restrict Network Access:** Remote administration services should be accessible only from trusted administrator systems, VPNs, or authorized network segments.
5. **Use a VPN:** Administrators can first connect through a secure VPN and then access internal management services.

6. Use a Bastion Host: A controlled jump server can provide a secure and monitored point through which administrators access internal servers.
7. Apply Firewall Rules: Only the required remote-administration ports should be permitted, while unnecessary services should be blocked.

5. Security Hardening

After identifying the remote administration services, the server should be hardened.

- Disable Telnet: If Telnet is not required, it should be completely disabled.
- Enable Secure Administration: Use SSH or another appropriately secured remote-administration mechanism.
- Limit Login Attempts: Implement controls to reduce repeated unauthorized authentication attempts.
- Keep Services Updated: Remote administration software should be regularly patched to address known vulnerabilities.
- Monitor Authentication Logs: Failed and unusual login attempts should be monitored for suspicious activity.
- Apply Least Privilege: Remote users should receive only the permissions necessary to perform their administrative tasks.

6. Actionable Security Priority

The findings can be prioritized according to their potential impact:

- Critical / P1: An insecure remote administration service such as Telnet is publicly or broadly accessible and allows privileged administration.
Action: Disable the service immediately and replace it with a secure alternative.
- High / P2: A remote administration service is accessible from an untrusted network or has weak authentication controls.
Action: Restrict access, strengthen authentication, and apply security updates.
- Medium / P3: A required administration service is securely configured but accessible to a wider network than necessary.
Action: Restrict access using firewall rules, VPNs, or trusted IP addresses.
- Low / Informational: A required remote administration service is properly secured but requires additional hardening or monitoring.
Action: Apply security best practices and continue monitoring.

Example

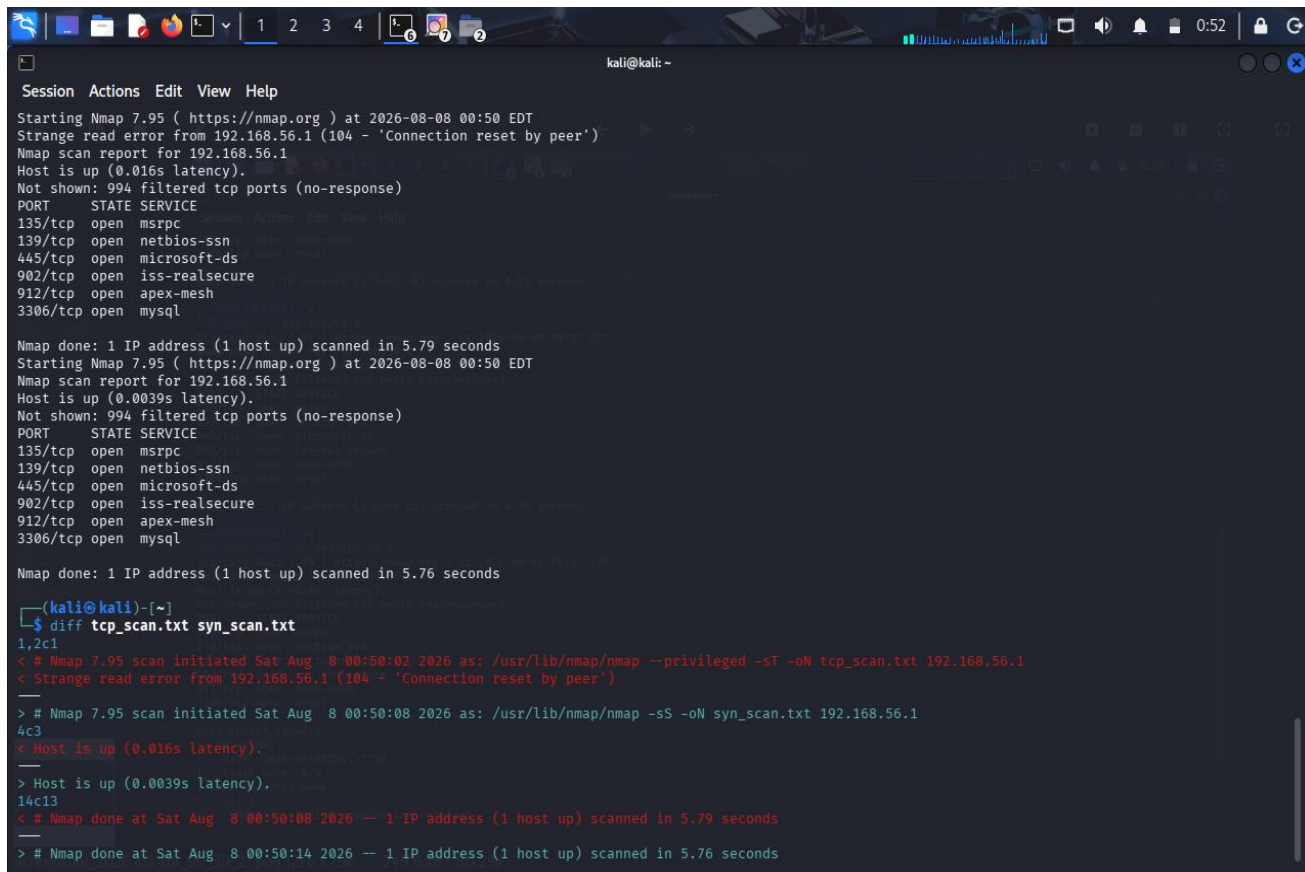
If the assessment finds that Telnet is accessible on 192.168.1.50, it should be treated as a security concern because Telnet does not provide secure encrypted communication. An attacker who can observe the network traffic may obtain sensitive authentication information.

The recommended solution is to disable Telnet and use SSH for remote administration. SSH should be properly configured with strong authentication, restricted network access, and regular security updates.

Conclusion

The Telnet assessment of 192.168.1.50 helps determine whether remote administration services are accessible and whether they introduce security risks. Telnet is particularly concerning because it does not adequately

protect sensitive communication. Unnecessary remote services should be disabled, while required administration should use secure alternatives such as SSH, supported by strong authentication, firewall restrictions, VPN access, and continuous monitoring.



```
kali@kali: ~  
Session Actions Edit View Help  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-08 00:50 EDT  
Strange read error from 192.168.56.1 (104 - 'Connection reset by peer')  
Nmap scan report for 192.168.56.1  
Host is up (0.016s latency).  
Not shown: 994 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
135/tcp   open  msrpc  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
902/tcp   open  iss-realservice  
912/tcp   open  apex-mesh  
3306/tcp  open  mysql  
  
Nmap done: 1 IP address (1 host up) scanned in 5.79 seconds  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-08 00:50 EDT  
Nmap scan report for 192.168.56.1  
Host is up (0.0039s latency).  
Not shown: 994 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
135/tcp   open  msrpc  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
902/tcp   open  iss-realservice  
912/tcp   open  apex-mesh  
3306/tcp  open  mysql  
  
Nmap done: 1 IP address (1 host up) scanned in 5.76 seconds  
  
(kali@kali)-[~]  
$ diff tcp_scan.txt syn_scan.txt  
1,2c1  
# Nmap 7.95 scan initiated Sat Aug  8 00:50:02 2026 as: /usr/lib/nmap/nmap --privileged -sT -oN tcp_scan.txt 192.168.56.1  
# Strange read error from 192.168.56.1 (104 - 'Connection reset by peer')  
--  
> # Nmap 7.95 scan initiated Sat Aug  8 00:50:08 2026 as: /usr/lib/nmap/nmap -sS -oN syn_scan.txt 192.168.56.1  
4c3  
# Host is up (0.016s latency).  
--  
> Host is up (0.0039s latency).  
14c13  
# Nmap done at Sat Aug  8 00:50:08 2026 -- 1 IP address (1 host up) scanned in 5.79 seconds  
--  
> # Nmap done at Sat Aug  8 00:50:14 2026 -- 1 IP address (1 host up) scanned in 5.76 seconds
```

5. Using Net discover, perform host discovery on the network segment 192.168.1.1–50. Identify active hosts on the network and analyze how the discovered information could assist an attacker in planning further enumeration or exploitation activities..

A. Performing host discovery using Netdiscover helps identify active devices within the network segment 192.168.1.1–50. The goal is to determine which hosts are active, collect basic network information about them, and analyze how this information could be useful during further security assessment or reconnaissance.

Here is a structured approach to assessing the network:

1. Active Host Identification

The first step is to identify the systems that are currently active within the specified network range.

- **IP Address Identification:** Netdiscover can identify IP addresses that are responding on the local network. Each active IP address represents a device that may provide network services.
- **MAC Address Identification:** The MAC address associated with an active host can provide additional information about the device.
- **Vendor Identification:** The MAC address can sometimes be used to identify the manufacturer of the network interface, such as a computer, router, mobile device, or other network equipment.

- **Host Enumeration:** The discovered IP addresses can be recorded to create an inventory of active systems within the network segment.

2. Analysis of Discovered Information

The information obtained from host discovery can provide an overview of the network.

- **Active Systems:** Identifying active hosts helps determine which systems are currently connected to the network.
- **Network Devices:** Devices such as routers, servers, workstations, printers, and other network-enabled systems may be identified based on their addresses and vendor information.
- **Device Classification:** Vendor information and network placement can provide clues about the possible type of device.
- **Network Structure:** The collection of active IP and MAC addresses can help create a basic understanding of the systems present within the network.

3. Security Risks

Although host discovery itself does not directly compromise a system, the information obtained can assist an attacker during reconnaissance.

- **Target Identification:** Attackers can identify which IP addresses correspond to active systems rather than wasting effort on inactive addresses.
- **Target Prioritization:** Servers, routers, and other important network devices may be prioritized for further investigation.
- **Network Mapping:** A list of active hosts helps an attacker build a basic map of the network environment.
- **Further Enumeration:** Once active systems are identified, attackers may attempt to determine what services, applications, or operating systems are available on those systems.
- **Potential Attack Planning:** Information about active devices can help attackers decide which systems may be more valuable or vulnerable targets.

4. How Attackers Could Use the Information

The discovered information can assist an attacker during the reconnaissance phase in several ways:

1. **Identify Active Hosts:** Attackers can determine which IP addresses belong to active devices.
2. **Identify Important Devices:** Vendor and network information may provide clues about routers, servers, workstations, or other devices.
3. **Prioritize Targets:** Systems that appear to provide important network functions may receive greater attention.
4. **Perform Further Enumeration:** Attackers may investigate the identified hosts to determine available services and applications.
5. **Search for Vulnerabilities:** Once services and software are identified, attackers may research known vulnerabilities associated with those technologies.
6. **Plan Further Attacks:** The collected information can help an attacker select potential targets and determine which systems require additional investigation.

5. Security Measures

The following measures can reduce the risks associated with network host discovery:

1. **Network Segmentation:** Separate critical servers and sensitive systems into protected network segments.
2. **Firewall Configuration:** Restrict unnecessary network communication between different systems and network segments.
3. **Access Control:** Allow only authorized devices and users to access sensitive network resources.
4. **Network Monitoring:** Monitor unusual host-discovery and scanning activity within the network.
5. **Disable Unnecessary Services:** Reduce the number of services exposed by active systems.
6. **Use Network Security Controls:** Appropriate intrusion detection and prevention mechanisms can help identify suspicious scanning activity.
7. **Maintain an Asset Inventory:** Administrators should regularly maintain an accurate list of authorized devices on the network.

6. Actionable Security Priority

The discovered hosts can be categorized according to their importance:

- **Critical / P1:** Active hosts containing sensitive data or providing critical network infrastructure.
Action: Apply strong access controls, segmentation, and continuous monitoring.
- **High / P2:** Servers or administrative systems that provide important services.
Action: Restrict access and ensure that exposed services are securely configured and updated.
- **Medium / P3:** Normal workstations and devices that have network connectivity.
Action: Apply endpoint security, firewall controls, and regular updates.
- **Low / Informational:** Unknown or non-critical devices identified during discovery.
Action: Verify whether the device is authorized and maintain it in the network inventory.

Example

If Netdiscover identifies several active hosts within 192.168.1.1–50, the IP addresses and MAC/vendor information can be recorded. For example, a host identified as a likely server would be considered more important for further security assessment than a normal workstation.

An attacker could use the list of active hosts to determine which systems are available and then perform additional enumeration against selected systems. Therefore, organizations should use network segmentation, access controls, monitoring, and proper firewall configurations to reduce unnecessary exposure.

Conclusion

Netdiscover host discovery of the 192.168.1.1–50 network segment helps identify active hosts, IP addresses, MAC addresses, and vendor information. This information provides a basic view of the network and can assist an attacker in identifying potential targets and planning further enumeration. To reduce this risk, organizations should implement network segmentation, access controls, firewall rules, monitoring, and proper device management.

```

kali@kali: ~
Session Actions Edit View Help
21/tcp filtered ftp

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.69 seconds

kali@kali:~$ sudo nmap -sV -p 3306,5432,6379,27017 192.168.56.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-08 00:58 EDT
Nmap scan report for 192.168.56.1
Host is up (0.0033s latency).

PORT      STATE SERVICE VERSION
3306/tcp   open  mysql   MySQL (unauthorized)
5432/tcp   filtered postgresql
6379/tcp   filtered redis
27017/tcp  filtered mongod

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.71 seconds

kali@kali:~$ sudo nmap --script vuln -sV 192.168.56.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-08 00:58 EDT
Nmap scan report for 192.168.56.1
Host is up (0.0045s latency).
Not shown: 994 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
135/tcp   open  msrpc   Microsoft Windows RPC
139/tcp   open  netbios-ssn Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
902/tcp   open  ssl/vmware-auth VMware Authentication Daemon 1.10 (Uses VNC, SOAP)
|_ssl-ccs-injection: No reply from server (TIMEOUT)
912/tcp   open  vmware-auth VMware Authentication Daemon 1.0 (Uses VNC, SOAP)
3306/tcp   open  tcpwrapped
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_smb-vuln-ms10-061: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR
|_smb-vuln-ms10-054: false
|_samba-vuln-cve-2012-1182: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 37.19 seconds

```

Code of Conduct:

I K. Venkata Karthik 192372092 certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

K. Venkata Karthik

Q.No	Identification of Port Scanning Factors(25)	Analysis(25)	Linkage(20)	Application(20)	Clarity(10)	Marks
1						
2						
3						
4						
5						

Signature of Faculty

Total Avg :

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
----------	-----------	---------------------	----------------------	----------------------	---------------------

Identification of Port Scanning Factors	25%	Clearly identifies comprehensive and relevant strengths, weaknesses, opportunities, and threats	Identifies most factors with minor gaps	Limited or partially relevant identification	Incorrect or incomplete Port Scanning factors
Analysis	25%	Provides deep, insightful analysis of each Port Scanning component with strong reasoning	Provides good analysis with some depth	Basic analysis with limited reasoning	No meaningful analysis provided
Linkage	20%	Effectively links Port Scanning elements to derive strong strategic insights and implications	Shows some linkage with moderate insights	Weak linkage; limited strategic thinking	No linkage or strategic insight
Application	20%	Applies Port Scanning analysis effectively to the given case or scenario with clear relevance	Applies analysis with minor gaps	Limited application; lacks clarity	No clear application to context
Clarity	10%	Well-structured, clear, and logically presented with proper formatting	Generally clear with minor issues	Some structure but lacks clarity	Poorly organized and difficult to understand